САНКТ-ПЕТЕРБУРГСКИЙ НАЦИОНАЛЬНЫЙ ИССЛЕДОВАТЕЛЬСКИЙ УНИВЕРСИТЕТ ИТМО

Дисциплина: Бэк-энд разработка

Отчет

Домашнее задание №2
“ Проектирование и технический дизайн API”

Выполнил:
Мохаджер Али Реза

Группа
K3340

Проверил:
Добряков Д. И.

Санкт-Петербург

2026 г.

Задача

1. Опишите все функциональные и нефункциональные требования к вашему бэкенд-приложению
2. Выберите формат реализации API, которого вы будете придерживаться: REST API или Backend For Frontend
3. Спроектируйте все эндпоинты вашего API в формате OpenAPI-схемы с учётом реализованной диаграммы БД
4. Опишите тело каждого запроса и тело каждого ответа, продумайте возможные ошибки, возвращаемые из API

Ход работы

Функциональные требования:

- Регистрация и авторизация пользователей
- Каталог ковров с фильтрацией по категории, форме, материалу, цвету, цене
- Страница товара с фотографиями и характеристиками
- Корзина покупок
- Оформление и отслеживание заказов
- Отзывы и рейтинги товаров
- Личный кабинет покупателя
- Панель администратора

Нефункциональные требования

- Формат API: REST API
- Аутентификация: Bearer JWT
- Формат данных: JSON
- Пагинация для списков (limit/offset)
- Все защищённые маршруты требуют заголовок Authorization: Bearer

Формат реализации API:
Выбран формат REST API. Каждый ресурс имеет отдельный URL; действия над ресурсом выражаются HTTP-методами (GET, POST, PATCH, DELETE). Версионирование выполняется через префикс /api/v1.

Обзор эндпоинтов

В таблице ниже перечислены все эндпоинты API с указанием метода, пути и краткого описания.

Метод	Путь	Описание
POST	/auth/register	Регистрация нового пользователя
POST	/auth/login	Авторизация; возвращает JWT
GET	/users/me	Профиль текущего пользователя
PATCH	/users/me	Обновление профиля
DELETE	/users/me	Удаление аккаунта
GET	/users/me/orders	История заказов текущего пользователя
GET	/users/me/reviews	Отзывы текущего пользователя
GET	/categories	Список всех категорий
POST	/categories	Создать категорию (админ)
GET	/categories/{id}	Получить категорию по ID
PATCH	/categories/{id}	Обновить категорию (админ)
DELETE	/categories/{id}	Удалить категорию (админ)
GET	/carpets	Список ковров с фильтрами и пагинацией
POST	/carpets	Создать товар (админ)
GET	/carpets/{id}	Карточка ковра
PATCH	/carpets/{id}	Обновить ковёр (админ)
DELETE	/carpets/{id}	Удалить ковёр (админ)
GET	/carpets/{id}/images	Фотографии ковра
POST	/carpets/{id}/images	Добавить фото (админ)
DELETE	/carpets/{carpet_id}/images/{image_id}	Удалить фото (админ)
GET	/carpets/{id}/reviews	Отзывы к ковру
POST	/carpets/{id}/reviews	Оставить отзыв (после покупки)
PATCH	/carpets/{carpet_id}/reviews/{review_id}	Обновить отзыв (автор / админ)
DELETE	/carpets/{carpet_id}/reviews/{review_id}	Удалить отзыв (автор / админ)
GET	/cart	Получить корзину

POST	/cart/items	Добавить товар в корзину
PATCH	/cart/items/{item_id}	Изменить количество в корзине
DELETE	/cart/items/{item_id}	Удалить позицию из корзины
DELETE	/cart/clear	Очистить корзину
POST	/orders	Оформить заказ из корзины
GET	/orders/{id}	Получить заказ (владелец / admin)
POST	/orders/{id}/cancel	Отменить заказ (владелец, PENDING)
GET	/admin/users	Все пользователи (admin)
GET	/admin/users/{id}	Пользователь по ID (admin)
DELETE	/admin/users/{id}	Удалить пользователя (admin)
PATCH	/admin/users/{id}/role	Изменить роль (admin)
GET	/admin/orders	Все заказы с фильтром (admin)
PATCH	/admin/orders/{id}/status	Изменить статус заказа (admin)

Детальное описание эндпоинтов

Аутентификация

POST /auth/register — Регистрация

Открытый эндпоинт. Создаёт нового пользователя с ролью CUSTOMER.

Тело запроса:

Поле	Тип	Описание
first_name	string (required)	Имя пользователя
last_name	string (required)	Фамилия
email	string (required)	Email — должен быть уникальным в системе
password	string (required)	Пароль, минимум 8 символов
phone	string (optional)	Номер телефона, например +79991234567

Тело ответа 201 Created:

Поле	Тип	Описание
token	string	JWT-токен для дальнейших запросов
user.id	uuid	Идентификатор созданного пользователя
user.role	string	Роль: CUSTOMER
user.email	string	Email пользователя
user.first_name	string	Имя
user.last_name	string	Фамилия
user.phone	string?	Телефон (null если не указан)
user.is_verified	boolean	Флаг верификации (false при регистрации)
user.created_at	datetime	Дата создания (ISO 8601)
user.updated_at	datetime	Дата обновления (ISO 8601)

Возможные ошибки:

HTTP код	Условие	Тело ответа (message)
400	email не передан / не соответствует формату	"Поле email обязательно и должно быть валидным email-адресом"
400	password короче 8 символов	"Пароль должен содержать минимум 8 символов"
400	first_name или last_name не переданы	"Поля first_name и last_name обязательны"
400	Пользователь с таким email уже существует	"Пользователь с таким email уже зарегистрирован"

POST /auth/login — Авторизация

Открытый эндпоинт. Принимает email и пароль, возвращает JWT.

Тело запроса:

Поле	Тип	Описание
email	string (required)	Email зарегистрированного пользователя
password	string (required)	Пароль

Тело ответа 200 OK:

Поле	Тип	Описание
token	string	JWT-токен
user	object	Полный профиль пользователя (те же поля, что при регистрации)

Возможные ошибки:

HTTP код	Условие	Тело ответа (message)
400	Не передан email или password	"Поля email и password обязательны"
401	Пользователь не найден или пароль неверен	"Неверный email или пароль"

Пользователи (/users/me)

Все эндпоинты раздела требуют авторизации (Bearer JWT).

GET /users/me — Профиль текущего пользователя

Тело запроса: отсутствует.

Тело ответа 200 OK:

Поле	Тип	Описание
id	uuid	Идентификатор пользователя
role	string	ADMIN или CUSTOMER
first_name	string	Имя
last_name	string	Фамилия
email	string	Email
phone	string?	Телефон
is_verified	boolean	Верифицирован ли аккаунт
created_at	datetime	Дата регистрации
updated_at	datetime	Дата последнего обновления

Возможные ошибки:

HTTP код	Условие	Тело ответа (message)
401	Токен не передан или просрочен	"Необходима авторизация"

PATCH /users/me — Обновление профиля

Тело запроса (все поля опциональны, передаётся только то, что меняется):

Поле	Тип	Описание
first_name	string (optional)	Новое имя
last_name	string (optional)	Новая фамилия
phone	string (optional)	Новый телефон
password	string (optional)	Новый пароль, минимум 8 символов

Тело ответа 200 OK: обновлённый объект пользователя (те же поля, что у GET /users/me).

Возможные ошибки:

HTTP код	Условие	Тело ответа (message)
400	password передан, но короче 8 символов	"Пароль должен содержать минимум 8 символов"
401	Токен не передан или просрочен	"Необходима авторизация"

DELETE /users/me — Удаление аккаунта

Тело запроса: отсутствует. Тело ответа: отсутствует (204 No Content).

Возможные ошибки:

HTTP код	Условие	Тело ответа (message)
401	Токен не передан или просрочен	"Необходима авторизация"

GET /users/me/orders — История заказов

Тело запроса: отсутствует.

Тело ответа 200 OK: массив объектов OrderShortRead:

Поле	Тип	Описание
[].id	uuid	Идентификатор заказа
[].status	string	PENDING | PAID | SHIPPED | DELIVERED | CANCELED
[].total_price	number	Итоговая сумма заказа
[].address	string	Адрес доставки
[].created_at	datetime	Дата оформления
[].updated_at	datetime	Дата последнего изменения

Возможные ошибки:

HTTP код	Условие	Тело ответа (message)
401	Токен не передан или просрочен	"Необходима авторизация"

GET /users/me/reviews — Отзывы пользователя

Тело запроса: отсутствует.

Тело ответа 200 OK: массив объектов ReviewRead:

Поле	Тип	Описание
[].id	uuid	Идентификатор отзыва
[].carpet_id	uuid	ID товара, на который оставлен отзыв
[].rating	integer	Оценка от 1 до 5
[].comment	string?	Текст комментария (может быть null)
[].created_at	datetime	Дата публикации

Возможные ошибки:

HTTP код	Условие	Тело ответа (message)
401	Токен не передан или просрочен	"Необходима авторизация"

Категории (/categories)

GET /categories и GET /categories/{id} — открытые эндпоинты. POST, PATCH, DELETE требуют роли ADMIN.

GET /categories — Список категорий

Параметры запроса: отсутствуют. Тело запроса: отсутствует.

Тело ответа 200 OK: массив объектов CategoryRead:

Поле	Тип	Описание
[].id	uuid	Идентификатор категории
[].title	string	Название категории
[].description	string?	Описание
[].is_published	boolean	Опубликована ли категория
[].created_at	datetime	Дата создания
[].updated_at	datetime	Дата обновления

POST /categories — Создать категорию (ADMIN)

Тело запроса:

Поле	Тип	Описание
title	string (required)	Название категории
description	string (optional)	Описание
is_published	boolean (optional)	По умолчанию true

Тело ответа 201 Created: объект CategoryRead (те же поля, что в списке).

Возможные ошибки:

HTTP код	Условие	Тело ответа (message)
400	Поле title не передано	"Поле title обязательно"
401	Токен не передан или просрочен	"Необходима авторизация"
403	Роль пользователя не ADMIN	"Доступ запрещён"

PATCH /categories/{id} — Обновить категорию (ADMIN)

Параметры пути: id — UUID категории.

Тело запроса (все поля опциональны):

Поле	Тип	Описание
title	string (optional)	Новое название
description	string (optional)	Новое описание
is_published	boolean (optional)	Скрыть или опубликовать

Тело ответа 200 OK: обновлённый объект CategoryRead.

Возможные ошибки:

HTTP код	Условие	Тело ответа (message)
400	Тело запроса пустое (нет ни одного поля)	"Необходимо передать хотя бы одно поле для обновления"
401	Токен не передан или просрочен	"Необходима авторизация"
403	Роль пользователя не ADMIN	"Доступ запрещён"
404	Категория с указанным id не найдена	"Категория не найдена"

DELETE /categories/{id} — Удалить категорию (ADMIN)

Тело запроса: отсутствует. Тело ответа: отсутствует (204 No Content).

Возможные ошибки:

HTTP код	Условие	Тело ответа (message)
401	Токен не передан или просрочен	"Необходима авторизация"
403	Роль пользователя не ADMIN	"Доступ запрещён"
404	Категория с указанным id не найдена	"Категория не найдена"

Ковры (/carpets)

GET-эндпоинты открыты. POST, PATCH, DELETE требуют роли ADMIN.

GET /carpets — Список ковров

Query-параметры (все опциональны):

Поле	Тип	Описание
category_id	uuid	Фильтр по категории
shape	string	RECTANGLE | SQUARE | CIRCLE | OVAL | RUNNER | CUSTOM
material	string	Фильтр по материалу (частичное совпадение)
color	string	Фильтр по цвету
is_handmade	boolean	true — только ручная работа
price_min	number	Минимальная цена (включительно)
price_max	number	Максимальная цена (включительно)
limit	integer	Количество записей (по умолчанию 20)
offset	integer	Смещение для пагинации (по умолчанию 0)

Тело ответа 200 OK (страница с пагинацией):

Поле	Тип	Описание
total	integer	Общее количество записей, удовлетворяющих фильтрам
limit	integer	Применённый limit
offset	integer	Применённый offset
items	array	Массив объектов CarpetShortRead (см. ниже)
items[].id	uuid	Идентификатор ковра
items[].title	string	Название
items[].category	object	Вложенный объект категории (id, title)
items[].price	number	Цена
items[].stock	integer	Остаток на складе

items[].shape	string	Форма
items[].material	string	Материал
items[].color	string	Цвет
items[].is_handmade	boolean	Ручная работа
items[].is_published	boolean	Опубликован
items[].main_image_url	string?	URL главного фото (null если не задано)
total	integer	Общее количество записей, удовлетворяющих фильтрам
limit	integer	Применённый limit

POST /carpets — Создать ковёр (ADMIN)

Тело запроса:

Поле	Тип	Описание
title	string (required)	Название товара
category_id	uuid (required)	ID категории
price	number (required)	Цена, >= 0
stock	integer (required)	Остаток на складе, >= 0
shape	string (required)	Форма: RECTANGLE | SQUARE | CIRCLE | OVAL | RUNNER | CUSTOM
description	string (optional)	Описание
length	number (optional)	Длина (для RECTANGLE, RUNNER)
width	number (optional)	Ширина (для RECTANGLE, SQUARE)
diameter	number (optional)	Диаметр (для CIRCLE)
material	string (optional)	Материал

pattern	string (optional)	Узор
color	string (optional)	Цвет
is_handmade	boolean (optional)	Ручная работа, по умолчанию false
is_published	boolean (optional)	Публикация, по умолчанию false

Тело ответа 201 Created: полный объект CarpetFullRead (все поля CarpetShortRead + description, размеры, images[], created_at, updated_at).

Возможные ошибки:

HTTP код	Условие	Тело ответа (message)
400	Не переданы обязательные поля	"Поля title, category_id, price, stock, shape обязательны"
400	price < 0 или stock < 0	"Цена и количество не могут быть отрицательными"
400	Недопустимое значение shape	"Недопустимое значение shape"
401	Токен не передан или просрочен	"Необходима авторизация"
403	Роль пользователя не ADMIN	"Доступ запрещён"
404	Категория с category_id не найдена	"Категория не найдена"

GET /carpets/{id} — Карточка ковра

Тело запроса: отсутствует.

Тело ответа 200 OK: объект CarpetFullRead — все поля CarpetShortRead плюс:

Поле	Тип	Описание
description	string?	Описание товара
length	number?	Длина (null если неприменимо)
width	number?	Ширина (null если неприменимо)
diameter	number?	Диаметр (null если неприменимо)
pattern	string?	Узор
images	array	Массив фотографий: [{id, image_url, is_main, created_at}]
created_at	datetime	Дата добавления
updated_at	datetime	Дата последнего изменения

Возможные ошибки:

HTTP код	Условие	Тело ответа (message)
404	Ковёр с указанным id не найден	"Товар не найден"

PATCH /carpets/{id} — Обновить ковёр (ADMIN)

Тело запроса: те же поля, что у POST /carpets, все опциональны.
Тело ответа 200 OK: обновлённый объект CarpetFullRead.

Возможные ошибки:

HTTP код	Условие	Тело ответа (message)
400	price < 0 или stock < 0	"Цена и количество не могут быть отрицательными"
400	Недопустимое значение shape	"Недопустимое значение shape"
401	Токен не передан или просрочен	"Необходима авторизация"
403	Роль пользователя не ADMIN	"Доступ запрещён"
404	Ковёр не найден	"Товар не найден"
404	category_id передан, но категория не найдена	"Категория не найдена"

DELETE /carpets/{id} — Удалить ковёр (ADMIN)

Тело запроса: отсутствует. Тело ответа: отсутствует (204 No Content).

Возможные ошибки:

HTTP код	Условие	Тело ответа (message)
401	Токен не передан или просрочен	"Необходима авторизация"
403	Роль пользователя не ADMIN	"Доступ запрещён"
404	Ковёр не найден	"Товар не найден"

Фотографии ковра (/carpets/{id}/images)

GET /carpets/{id}/images — Список фотографий

Открытый эндпоинт. Тело запроса: отсутствует.
Тело ответа 200 OK: массив объектов:

Поле	Тип	Описание
[].id	uuid	Идентификатор фото
[].image_url	string	URL изображения
[].is_main	boolean	Является ли фото главным
[].created_at	datetime	Дата загрузки

Возможные ошибки:

HTTP код	Условие	Тело ответа (message)
404	Ковёр с указанным id не найден	"Товар не найден"

POST /carpets/{id}/images — Добавить фото (ADMIN)

Тело запроса:

Поле	Тип	Описание
image_url	string (required)	URL загруженного изображения
is_main	boolean (optional)	Сделать главным фото (по умолчанию false). При установке true — предыдущее главное фото теряет флаг.

Тело ответа 201 Created: объект фотографии {id, image_url, is_main, created_at}.

Возможные ошибки:

HTTP код	Условие	Тело ответа (message)
400	image_url не передан или пустой	"Поле image_url обязательно"
400	image_url не является валидным URL	"image_url должен быть корректным URL"
401	Токен не передан или просрочен	"Необходима авторизация"
403	Роль пользователя не ADMIN	"Доступ запрещён"
404	Ковёр не найден	"Товар не найден"

DELETE /carpets/{carpet_id}/images/{image_id} — Удалить фото (ADMIN)

Тело запроса: отсутствует. Тело ответа: отсутствует (204 No Content).

Возможные ошибки:

HTTP код	Условие	Тело ответа (message)
401	Токен не передан или просрочен	"Необходима авторизация"
403	Роль пользователя не ADMIN	"Доступ запрещён"
404	Ковёр не найден	"Товар не найден"
404	Фото с указанным image_id не найдено у ковра	"Фотография не найдена"

Отзывы (/carpets/{id}/reviews)

GET-эндпоинты открыты. Создание отзыва требует авторизации и факта покупки товара.

GET /carpets/{id}/reviews — Список отзывов

Query-параметры: limit (по умолчанию 20), offset (по умолчанию 0).

Тело ответа 200 OK: массив объектов ReviewRead:

Поле	Тип	Описание
[].id	uuid	Идентификатор отзыва
[].user	object	Автор: {id, first_name, last_name}
[].carpet_id	uuid	ID товара
[].rating	integer	Оценка 1–5
[].comment	string?	Текст отзыва (может быть null)
[].created_at	datetime	Дата публикации

Возможные ошибки:

HTTP код	Условие	Тело ответа (message)
404	Ковёр не найден	"Товар не найден"

POST /carpets/{id}/reviews — Оставить отзыв

Тело запроса:

Поле	Тип	Описание
rating	integer (required)	Оценка от 1 до 5 включительно
comment	string (optional)	Текст отзыва

Тело ответа 201 Created: объект ReviewRead.

Возможные ошибки:

HTTP код	Условие	Тело ответа (message)
400	rating не передан	"Поле rating обязательно"
400	rating вне диапазона 1–5	"Оценка должна быть от 1 до 5"
401	Токен не передан или просрочен	"Необходима авторизация"
403	Пользователь не покупал этот ковёр	"Отзыв можно оставить только после покупки товара"
404	Ковёр не найден	"Товар не найден"
409	Пользователь уже оставлял отзыв на этот товар	"Вы уже оставили отзыв на этот товар"

PATCH /carpets/{carpet_id}/reviews/{review_id} — Обновить отзыв

Доступно автору отзыва или ADMIN. Тело запроса (все поля опциональны):

Поле	Тип	Описание
rating	integer (optional)	Новая оценка 1–5
comment	string (optional)	Новый текст

Тело ответа 200 OK: обновлённый объект ReviewRead.

Возможные ошибки:

HTTP код	Условие	Тело ответа (message)
400	rating вне диапазона 1–5	"Оценка должна быть от 1 до 5"
401	Токен не передан или просрочен	"Необходима авторизация"
403	Пользователь не является автором отзыва и не ADMIN	"Доступ запрещён"
404	Ковёр или отзыв не найден	"Товар или отзыв не найден"

DELETE /carpets/{carpet_id}/reviews/{review_id} — Удалить отзыв

Доступно автору или ADMIN. Тело запроса: отсутствует. Тело ответа: отсутствует (204 No Content).

Возможные ошибки:

HTTP код	Условие	Тело ответа (message)
401	Токен не передан или просрочен	"Необходима авторизация"
403	Пользователь не является автором и не ADMIN	"Доступ запрещён"
404	Ковёр или отзыв не найден	"Товар или отзыв не найден"

Корзина (/cart)

Все эндпоинты раздела требуют авторизации. Корзина создаётся автоматически при регистрации пользователя.

GET /cart — Получить корзину

Тело запроса: отсутствует.

Тело ответа 200 OK:

Поле	Тип	Описание
id	uuid	Идентификатор корзины
items	array	Позиции корзины
items[].id	uuid	Идентификатор позиции
items[].carpet	object	Краткая карточка ковра (CarpetShortRead)
items[].quantity	integer	Количество единиц
items[].subtotal	number	Сумма по позиции (price × quantity)
items[].created_at	datetime	Дата добавления в корзину
total_price	number	Итоговая сумма по всем позициям
created_at	datetime	Дата создания корзины
updated_at	datetime	Дата последнего изменения

Возможные ошибки:

HTTP код	Условие	Тело ответа (message)
401	Токен не передан или просрочен	"Необходима авторизация"

POST /cart/items — Добавить товар в корзину

Тело запроса:

Поле	Тип	Описание
carpet_id	uuid (required)	ID ковра, который добавляется в корзину
quantity	integer (required)	Количество, >= 1

Тело ответа 201 Created: обновлённый объект корзины (CartRead, те же поля что у GET /cart).

Возможные ошибки:

HTTP код	Условие	Тело ответа (message)
400	carpet_id не передан	"Поле carpet_id обязательно"
400	quantity < 1	"Количество должно быть >= 1"
400	Запрошенное количество превышает остаток на складе	"Недостаточно товара на складе"
401	Токен не передан или просрочен	"Необходима авторизация"
404	Ковёр не найден или снят с публикации	"Товар не найден"

PATCH /cart/items/{item_id} — Изменить количество

Тело запроса:

Поле	Тип	Описание
quantity	integer (required)	Новое количество, >= 1

Тело ответа 200 OK: обновлённый объект корзины (CartRead).

Возможные ошибки:

HTTP код	Условие	Тело ответа (message)
400	quantity < 1	"Количество должно быть >= 1"
400	Запрошенное количество превышает остаток на складе	"Недостаточно товара на складе"
401	Токен не передан или просрочен	"Необходима авторизация"
404	Позиция с указанным item_id не найдена в корзине	"Позиция корзины не найдена"

DELETE /cart/items/{item_id} — Удалить позицию из корзины

Тело запроса: отсутствует.
Тело ответа 200 OK: обновлённая корзина (CartRead) после удаления позиции.

Возможные ошибки:

HTTP код	Условие	Тело ответа (message)
401	Токен не передан или просрочен	"Необходима авторизация"
404	Позиция с указанным item_id не найдена в корзине	"Позиция корзины не найдена"

DELETE /cart/clear — Очистить корзину

Тело запроса: отсутствует. Тело ответа: отсутствует (204 No Content).

Возможные ошибки:

HTTP код	Условие	Тело ответа (message)
401	Токен не передан или просрочен	"Необходима авторизация"

Заказы (/orders)

Все эндпоинты раздела требуют авторизации.

POST /orders — Оформить заказ

Создаёт заказ из всех позиций текущей корзины. После оформления корзина очищается, остатки на складе уменьшаются.

Тело запроса:

Поле	Тип	Описание
address	string (required)	Адрес доставки, например: г. Москва, ул. Ленина 1, кв. 42

Тело ответа 201 Created: объект OrderFullRead:

Поле	Тип	Описание
id	uuid	Идентификатор заказа
status	string	Начальный статус: PENDING
total_price	number	Итоговая сумма (зафиксированная на момент оформления)
address	string	Адрес доставки
user	object	Покупатель: {id, first_name, last_name, email}
items	array	Позиции заказа
items[].id	uuid	Идентификатор позиции
items[].carpet	object	Краткая карточка ковра на момент покупки
items[].quantity	integer	Количество
items[].price	number	Цена за единицу на момент покупки (зафиксирована)
created_at	datetime	Дата оформления
updated_at	datetime	Дата последнего изменения

Возможные ошибки:

HTTP код	Условие	Тело ответа (message)
400	Поле address не передано	"Поле address обязательно"
400	Корзина пуста	"Корзина пуста — невозможно оформить заказ"
400	Один из товаров в корзине снят с публикации / закончился	"Товар \"Название\" недоступен в запрошенном количестве"
401	Токен не передан или просрочен	"Необходима авторизация"

GET /orders/{id} — Получить заказ

Доступно владельцу заказа или ADMIN. Тело запроса: отсутствует.
Тело ответа 200 OK: объект OrderFullRead (те же поля, что возвращает POST /orders).

Возможные ошибки:

HTTP код	Условие	Тело ответа (message)
401	Токен не передан или просрочен	"Необходима авторизация"
403	Пользователь не является владельцем и не ADMIN	"Доступ запрещён"
404	Заказ с указанным id не найден	"Заказ не найден"

POST /orders/{id}/cancel — Отменить заказ

Доступно только владельцу заказа и только в статусе PENDING. При отмене остатки на складе восстанавливаются.
Тело запроса: отсутствует.
Тело ответа 200 OK: обновлённый объект OrderFullRead со статусом CANCELED.

Возможные ошибки:

HTTP код	Условие	Тело ответа (message)
400	Статус заказа не PENDING (например, уже PAID или SHIPPED)	"Заказ нельзя отменить: текущий статус — PAID"
401	Токен не передан или просрочен	"Необходима авторизация"
403	Пользователь не является владельцем заказа	"Доступ запрещён"
404	Заказ с указанным id не найден	"Заказ не найден"

Администрирование (/admin)

Все эндпоинты раздела доступны только пользователям с ролью ADMIN.

GET /admin/users — Список всех пользователей

Query-параметры: limit (по умолчанию 50), offset (по умолчанию 0).
Тело ответа 200 OK: массив объектов UserFullRead (полный профиль с email, телефоном, ролью, датами).

Возможные ошибки:

HTTP код	Условие	Тело ответа (message)
401	Токен не передан или просрочен	"Необходима авторизация"
403	Роль пользователя не ADMIN	"Доступ запрещён"

GET /admin/users/{id} — Пользователь по ID

Тело запроса: отсутствует.
Тело ответа 200 OK: объект UserFullRead.

Возможные ошибки:

HTTP код	Условие	Тело ответа (message)
401	Токен не передан или просрочен	"Необходима авторизация"
403	Роль пользователя не ADMIN	"Доступ запрещён"
404	Пользователь с указанным id не найден	"Пользователь не найден"

DELETE /admin/users/{id} — Удалить пользователя

Тело запроса: отсутствует. Тело ответа: отсутствует (204 No Content).

Возможные ошибки:

HTTP код	Условие	Тело ответа (message)
401	Токен не передан или просрочен	"Необходима авторизация"
403	Роль пользователя не ADMIN	"Доступ запрещён"
404	Пользователь не найден	"Пользователь не найден"

PATCH /admin/users/{id}/role — Изменить роль

Тело запроса:

Поле	Тип	Описание
role	string (required)	Новая роль: ADMIN или CUSTOMER

Тело ответа 200 OK: обновлённый объект UserFullRead.

Возможные ошибки:

HTTP код	Условие	Тело ответа (message)
400	role не передан или недопустимое значение	"Допустимые значения role: ADMIN, CUSTOMER"
401	Токен не передан или просрочен	"Необходима авторизация"
403	Роль пользователя не ADMIN	"Доступ запрещён"
404	Пользователь не найден	"Пользователь не найден"

GET /admin/orders — Все заказы

Query-параметры: status (опционально, фильтр по статусу), limit (50), offset (0).
Тело ответа 200 OK: массив объектов OrderShortRead (id, status, total_price, address, created_at, updated_at).

Возможные ошибки:

HTTP код	Условие	Тело ответа (message)
400	Недопустимое значение status	"Допустимые значения: PENDING, PAID, SHIPPED, DELIVERED, CANCELED"
401	Токен не передан или просрочен	"Необходима авторизация"
403	Роль пользователя не ADMIN	"Доступ запрещён"

PATCH /admin/orders/{id}/status — Изменить статус заказа

Допустимые переходы: PENDING → PAID → SHIPPED → DELIVERED; любой статус → CANCELED (кроме DELIVERED).

Тело запроса:

Поле	Тип	Описание
status	string (required)	Новый статус: PENDING | PAID | SHIPPED | DELIVERED | CANCELED

Тело ответа 200 OK: обновлённый объект OrderFullRead.

Возможные ошибки:

HTTP код	Условие	Тело ответа (message)
400	Недопустимое значение status	"Допустимые значения status: PENDING, PAID, SHIPPED, DELIVERED, CANCELED"
400	Недопустимый переход статуса (например, SHIPPED → PENDING)	"Недопустимый переход статуса: SHIPPED → PENDING"
400	Попытка изменить статус заказа DELIVERED	"Статус доставленного заказа нельзя изменить"
401	Токен не передан или просрочен	"Необходима авторизация"
403	Роль пользователя не ADMIN	"Доступ запрещён"
404	Заказ с указанным id не найден	"Заказ не найден"

Вывод

В рамках данной работы были описаны все функциональные и нефункциональные требования к бэкенд-приложению интернет-магазина ковров. Выбран формат REST API с JWT-аутентификацией. Спроектированы 37 эндпоинтов, сгруппированных по 9 разделам: Authentication, Users, Categories, Carpets, CarpetImages, Reviews, Cart, Orders, Admin. Для каждого эндпоинта описано тело запроса, тело ответа и возможные HTTP-ошибки с сопроводительным сообщением. Схема соответствует спроектированной в ДЗ1 базе данных.